

Security Policy

Document Version: 1.0

Document Owner: Acme SaaS Inc.

Next Review Date: 2027-03-16

Last updated: 2026-03-16

Acme SaaS Inc. takes the security of our software and services seriously. If you believe you have found a security vulnerability, we encourage you to report it responsibly.

Supported Versions

We release patches for security vulnerabilities in the following versions:

Version	Supported
-----	-----
latest	:white_check_mark:
< latest	:x:

If you are using an older version, please upgrade to the latest release to receive security updates.

Reporting a Vulnerability

Please do NOT report security vulnerabilities through public GitHub issues.

Instead, please report them via email:

- **Email:** privacy@acme.com

Please include the following information in your report:

- Description of the vulnerability
- Steps to reproduce the issue

- Potential impact of the vulnerability
- Any suggested fixes (optional)

Scope

In Scope

- Acme SaaS Inc. application code and APIs
- Authentication and session management
- Data storage and transmission
- Infrastructure serving [<https://yoursite.com>]

Out of Scope

- Third-party services and applications
- Social engineering attacks
- Denial of service (DoS/DDoS) attacks
- Issues in dependencies that are already publicly disclosed

Authentication Security

This project uses authentication services. Security issues related to the following are especially important to us:

- Session management and token handling
- Authentication bypass vulnerabilities
- Credential storage and transmission
- OAuth flow and callback security

Payment & PCI Considerations

This project integrates with payment processing services. We follow PCI DSS guidelines for handling payment data:

- Payment card data is never stored on our servers; it is handled by our PCI-compliant payment processor
- Vulnerabilities related to payment flows, billing data exposure, or payment bypass are treated as **critical**

- If you discover a payment-related vulnerability, please include `[PCI]` in your report subject line

AI Safety & Security

This project integrates with AI/ML services. In addition to traditional security concerns, we are interested in reports related to:

- Prompt injection vulnerabilities
- Data leakage through AI model interactions
- Unauthorized access to AI-generated content
- Model manipulation or adversarial inputs
- AI output used to bypass security controls

Response Timeline

We are committed to responding to security reports promptly:

Action	Timeline
-----	-----
Acknowledgment of report	Within 48 hours
Initial assessment	Within 5 business days
Resolution target (critical)	Within 30 days
Resolution target (non-critical)	Within 90 days
Public disclosure (coordinated)	After fix is deployed

Disclosure Policy

We follow a coordinated disclosure process. We ask that you:

- Allow us reasonable time to investigate and address the vulnerability before public disclosure
- Make a good faith effort to avoid privacy violations, data destruction, and service disruption
- Do not access or modify data belonging to other users

Contact

For security-related inquiries, contact us at [privacy@acme.com]
(mailto:privacy@acme.com).

Review Notes

What a lawyer should check

- Verify security measures described match actual implementation
- Confirm responsible disclosure process is operational
- Check that response timelines are achievable
- Ensure contact information is current and monitored

Auto-generated vs. needs human input

Section	Status	Confidence
----- ----- -----		
Security practices	Template — needs verification	Medium
Reporting process	Standard template	Medium
Contact information	From config file	High

Related Documents

- Incident Response Plan (`INCIDENT\_RESPONSE\_PLAN.md`)
- Access Control Policy (`ACCESS\_CONTROL\_POLICY.md`)
- Encryption Policy (`ENCRYPTION\_POLICY.md`)
- Penetration Test Scope (`PENTEST\_SCOPE.md`)
- Information Security Policy (`INFORMATION\_SECURITY\_POLICY.md`)

*This security policy was generated by [Codepliant]
(<https://github.com/codepliant/codepliant>) based on an automated scan of the **acme-saas** codebase. It should be reviewed and customized by your security team before publishing.*

